

Aula 1 (Módulo 13) — Estrutura do MITRE ATT&CK: Táticas, Técnicas e Sub-técnicas

1. O que é o MITRE ATT&CK (visão simples)

MITRE é uma organização sem fins lucrativos americana que mantém vários projetos de referência em segurança e engenharia. **ATT&CK** (*Adversarial Tactics, Techniques, and Common Knowledge*) é um **catálogo público, gratuito e vivo** de comportamentos reais de atacantes, observados e documentados a partir de incidentes de verdade — não é teórico, é baseado em evidência de campo.

Já usamos dezenas de vezes esse catálogo neste curso, sem formalizar: toda vez que citamos "T1543", "T1059.001", "T1053.003", estávamos referenciando uma técnica específica do ATT&CK.

<https://attack.mitre.org/>

2. Por que ele existe: um vocabulário comum

Antes do ATT&CK ser amplamente adotado, cada empresa de segurança descrevia comportamento de ataque com seus próprios termos — dificultando comparar relatórios, compartilhar detecções, ou treinar pessoas de forma padronizada. O ATT&CK virou o **idioma comum** da indústria: quando alguém diz "T1055", qualquer analista treinado no mundo inteiro sabe exatamente do que se trata (Process Injection).

3. As Matrizes

O ATT&CK é dividido em **matrizes**, por ambiente:

- **Enterprise**: Windows, Linux, macOS, nuvem, redes corporativas — a matriz mais usada e a que mais citamos neste curso.
- **Mobile**: dispositivos Android/iOS.
- **ICS** (*Industrial Control Systems*): ambientes industriais/OT (sistemas de controle industrial, diferentes de TI corporativa tradicional).

4. A hierarquia: Tática → Técnica → Sub-técnica

Tática — o "porquê" (objetivo)

Uma tática é o **objetivo tático** do atacante naquele momento do ataque — **o quê** ele está tentando alcançar, não como. A matriz Enterprise tem 14 táticas, organizadas (aproximadamente) na ordem em que costumam ocorrer num ataque:

Reconnaissance → Resource Development → Initial Access → Execution → Persistence → Privilege Escalation → Defense Evasion → Credential Access → Discovery → Lateral Movement → Collection → Command and Control → Exfiltration → Impact

Já reconhecemos várias dessas sem o nome oficial: "Persistence" (Módulos 00, 02, 10 inteiros), "Command and Control" (o C2 mencionado desde o Módulo 00), "Discovery" (o Cenário 3 do Módulo 10, com `net user`), "Defense Evasion" (Módulo 02, Aula 3, desativar o Defender).

Técnica — o "como" (método)

Uma técnica é o **método específico** para alcançar aquela tática. Cada técnica tem um ID único, no formato `T####` (ex.: `T1543` — Create or Modify System Process).

Sub-técnica — o "como", mais específico

Muitas técnicas se dividem em sub-técnicas — variações mais específicas do mesmo método geral. Formato

`T####.###` :

T1053	Scheduled Task/Job (a técnica geral)
T1053.003	→ especificamente via Cron (Linux) — Módulo 01, Aula 3
T1053.005	→ especificamente via Scheduled Task (Windows) — Módulo 02, Aula 3

Por que a sub-técnica importa: a evidência e a detecção mudam completamente entre Cron e Scheduled Task, mesmo sendo a "mesma" técnica de nível geral — daí a necessidade de granularidade.

5. Navegando o site oficial

attack.mitre.org

- └ Matrices → Enterprise → visualização completa: táticas nas colunas, técnicas nas linhas abaixo de cada uma
- └ Techniques → busca/lista de todas as técnicas, com página própria para cada uma (descrição, sub-técnicas, procedimentos observados por grupos reais, e — muito importante — a seção "Detection", com sugestões oficiais de como detectar aquela técnica)
- └ Groups → threat actors rastreados publicamente, com as técnicas que cada um já usou (Módulo 12, Aula 1)
- └ Software → ferramentas/malwares catalogados, também ligados às técnicas que usam

Exercício de navegação: acesse a página oficial da técnica `T1543.003` (a sub-técnica específica de Windows Service, que citamos desde o Módulo 00, Aula 3) e observe a seção **"Detection"** — compare com o que já discutimos sobre Event ID 7045/4697 (Módulo 02, Aula 4).

6. Como cada técnica é documentada (anatomia de uma página)

Toda página de técnica no site oficial segue uma estrutura consistente:

- **Description:** explicação da técnica.
- **Procedure Examples:** exemplos reais, com o grupo/malware que usou aquela técnica especificamente daquele jeito (o "P" de TTP, Módulo 12).
- **Mitigations:** recomendações oficiais de como prevenir.
- **Detection:** fontes de dados e abordagens recomendadas para detectar.

Essa estrutura é, na prática, o esqueleto da metodologia que vamos usar na próxima aula: **Tática** → **Técnica** → **Procedimento** → **Evidência** → **Detecção** → **Resposta**.

7. Conectando com tudo que já vimos

Aqui está uma pequena amostra do que já estudamos, agora com seus IDs oficiais completos:

O que já vimos	Tática	Técnica
Run keys do Registry (Módulo 02, Aula 1)	Persistence	T1547.001
Serviço malicioso (Módulo 00, Aula 3)	Persistence	T1543.003
Cron malicioso (Módulo 01, Aula 3)	Persistence	T1053.003
Word abrindo PowerShell (Módulo 02, Aula 5)	Execution	T1059.001
ARP Spoofing (Módulo 03, Aula 2)	Credential Access / Collection	T1557.002
SUID malicioso (Módulo 01, Aula 7)	Privilege Escalation	T1548.001

8. Exercício prático

Acesse attack.mitre.org/matrices/enterprise/ e escolha **três** técnicas que apareceram nesta tabela. Para cada uma, leia a seção "Detection" da página oficial e compare com o que já discutimos nos módulos correspondentes — o que a página oficial menciona que ainda não vimos aqui?

9. Recapitulando

- MITRE ATT&CK é um catálogo público, gratuito, baseado em evidência real de incidentes — o vocabulário comum da indústria de segurança.
- Hierarquia: Tática (objetivo, "o quê") → Técnica (método, "como") → Sub-técnica (variação específica).
- Matrizes por ambiente (Enterprise, Mobile, ICS); cada técnica tem página própria com Description, Procedure Examples, Mitigations e Detection.
- Praticamente tudo que já estudamos neste curso mapeia diretamente para IDs oficiais do ATT&CK.

Próxima aula (fecha o Módulo 13)

Aplicando o framework completo: Tática → Técnica → Procedimento → Evidência → Detecção → Resposta, revisitando cenários que já investigamos, agora com a estrutura formal do ATT&CK.

Fontes recomendadas

- MITRE ATT&CK — página oficial: <https://attack.mitre.org/>
- MITRE ATT&CK — "Matrices": visualização completa oficial de todas as táticas/técnicas por ambiente. <https://attack.mitre.org/matrices/>
- MITRE — "ATT&CK Design and Philosophy" (whitepaper oficial): documento oficial explicando a estrutura e os princípios de design do framework. <https://attack.mitre.org/resources/attack-design-and-philosophy/>